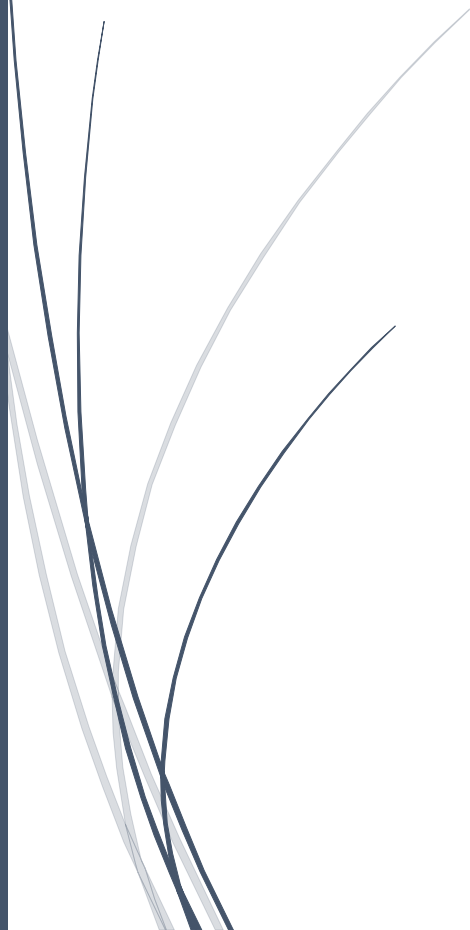




12-5-2026

Playbook

Práctica 5-1 → Incidentes



SAVU, RALUCA ALEXANDRA
CIPFP MISLATA

Contenido

1.	Descripción	2
2.	Fases del ataque	2
2.1.	Acceso Inicial	2
2.2.	Ejecución.....	2
2.3.	Persistencia.....	3
2.4.	Movimiento lateral	3
2.5.	Impacto	3
3.	Mapeo MITRE ATT&CK	3
4.	Playbook completo.....	4
4.1.	Detección (SOC Tier 1).....	4
4.2.	Análisis (SOC Tier 2).....	4
4.3.	Contención (Tier 2 / IT)	5
4.4.	Erradicación (Tier 3 / Forense)	6
4.5.	Recuperación (IT / Negocio)	6
4.6.	Lecciones aprendidas (CISO / SOC)	7
5.	Diagrama de flujo	7
6.	Escalado interno y externo	8
6.1.	Criterios de escalado interno	8
6.2.	Justificación del escalado externo	8

1. Descripción

El incidente detectado corresponde a un ataque de ransomware con movimiento lateral. Este tipo de ataque combina técnicas de cifrado de datos con la capacidad de propagarse lateralmente a través de la red corporativa, comprometiendo múltiples sistemas de forma simultánea o progresiva.

El ransomware es un tipo de malware que cifra los archivos del sistema víctima e impide el acceso a los mismos hasta que se abona un rescate económico al atacante. En este escenario concreto, el actor malicioso ha logrado escalar privilegios mediante la creación de cuentas administrativas fraudulentas y ha aprovechado el entorno de Active Directory para moverse lateralmente entre equipos de la red interna.

Las evidencias observadas son las siguientes:

- Archivos cifrados en múltiples endpoints.
- Creación de cuentas administrativas sospechosas.
- Tráfico lateral entre sistemas internos mediante protocolo SMB.
- Nota de rescate depositada en servidores de ficheros compartidos.
- Ejecución remota de PowerShell con descarga de payload malicioso.

2. Fases del ataque

2.1. Acceso Inicial

El atacante obtiene un primer punto de entrada en la red corporativa. Aunque el vector exacto no ha sido confirmado, los logs apuntan a un acceso remoto desde la IP 10.0.5.23 con el usuario admin_temp, lo que sugiere un posible ataque de fuerza bruta previo (15 intentos fallidos registrados con EventID 4625) o el uso de credenciales comprometidas obtenidas previamente.

2.2. Ejecución

Una vez dentro del sistema, el atacante ejecuta comandos maliciosos a través de PowerShell (powershell.exe) para descargar un payload desde un servidor externo (malicious-site.com/payload.exe). Esto permite instalar el componente encryptor.exe en el sistema comprometido y preparar el ataque de cifrado.

2.3. Persistencia

El atacante garantiza su permanencia en el sistema mediante la creación de la cuenta administrativa `admin_temp`, lo que le permite mantener acceso al entorno, aunque se detecte y elimine el malware inicial. Esta cuenta aparece en los logs con accesos remotos (**LogonType: 10**) en horas inusuales (**02:14 AM**).

2.4. Movimiento lateral

Aprovechando el protocolo `SMB`, el atacante se desplaza desde el equipo comprometido (`10.0.5.23`) hacia otros sistemas de la red interna (`10.0.8.12`). Esta técnica le permite alcanzar los servidores de ficheros compartidos y maximizar el impacto del cifrado.

2.5. Impacto

El proceso `encryptor.exe` cifra los archivos de los endpoints y servidores afectados, añadiendo la extensión `.locked` a cada fichero. Finalmente, se deposita una nota de rescate en los servidores compartidos para comunicar las exigencias económicas a la organización víctima.

3. Mapeo MITRE ATT&CK

A continuación, se enumeran las tácticas y técnicas del framework MITRE ATT&CK observadas en este ataque:

Código	Táctica	Técnica	Descripción
T1078	Initial Access / Persistence	Valid Accounts	Uso de cuenta <code>admin_temp</code> con credenciales válidas para acceder remotamente.
T1059.001	Execution	PowerShell	Ejecución de <code>Invoke-WebRequest</code> para descargar payload malicioso.
T1021.002	Lateral Movement	SMB/Windows Admin Shares	Transferencia de ficheros y propagación vía protocolo SMB entre <code>10.0.5.23</code> y <code>10.0.8.12</code> .
T1486	Impact	Data Encrypted for Impact	Cifrado masivo de archivos con extensión <code>.locked</code> mediante <code>encryptor.exe</code> .

T1110	Credential Access	Brute Force	15 intentos fallidos de autenticación (EventID 4625) desde 10.0.5.23.
T1136.001	Persistence	Create Account: Local Account	Creación de cuenta administrativa sospechosa (admin_temp) para mantener acceso.

4. Playbook completo

4.1. Detección (SOC Tier 1)

Alertas que disparan el playbook:

- Alerta SIEM por múltiples intentos de autenticación fallidos (EventID 4625, más de 10 intentos en menos de 5 minutos).
- Alerta EDR por ejecución de powershell.exe con parámetro Invoke-WebRequest hacia dominio externo desconocido.
- Alerta de integridad de ficheros por renombrado masivo de archivos con extensión desconocida (.locked).
- Alerta de red por tráfico SMB inusual entre endpoints que normalmente no se comunican entre sí.
- Detección de nota de rescate (ransom note) en carpetas compartidas.

Indicadores clave (IoCs):

- IP origen de acceso remoto sospechoso: 10.0.5.23.
- Usuario: admin_temp (cuenta no reconocida en el directorio corporativo).
- Acceso remoto a las 02:14 AM (fuera del horario laboral habitual).
- Proceso encryptor.exe no catalogado en la whitelist de aplicaciones.
- Dominio malicioso: malicious-site.com.
- Archivos con extensión **.locked** en múltiples rutas del sistema.
- Nota de rescate depositada en servidor compartido.

4.2. Análisis (SOC Tier 2)

Logs a revisar:

- **Windows Security Event Log:** EventID 4624 (inicio de sesión exitoso), EventID 4625 (intentos fallidos), EventID 4720 (creación de cuenta).
- **PowerShell ScriptBlock Logging:** historial de comandos ejecutados por admin_temp.

- **EDR telemetry:** árbol de procesos de encryptor.exe, conexiones de red generadas, ficheros creados o modificados.
- **SIEM:** correlación de eventos de autenticación, ejecución y tráfico de red en la ventana temporal del incidente.
- **Logs SMB del servidor de ficheros:** conexiones desde 10.0.5.23 hacia 10.0.8.12 con transferencias inusuales.

Confirmación de compromiso:

- Verificar que **admin_temp** no es una cuenta legítima consultando Active Directory.
- Confirmar la existencia de **encryptor.exe** en el sistema y analizar su hash en VirusTotal o sandbox.
- Comprobar que los ficheros .locked son inaccesibles y que la extensión no corresponde a ninguna aplicación corporativa.
- Validar la comunicación con **malicious-site.com** en los logs de proxy/firewall.
- Identificar todos los equipos afectados por el cifrado correlacionando alertas EDR.

4.3. Contención (Tier 2 / IT)

Acciones inmediatas:

- **Aislamiento de red:** desconectar de la red los equipos comprometidos (10.0.5.23 y 10.0.8.12) mediante VLAN de cuarentena o desactivación del puerto de switch correspondiente.
- **Bloqueo de cuentas:** deshabilitar la cuenta admin_temp en Active Directory de forma inmediata.
- **Bloqueo de IP:** añadir 10.0.5.23 a la lista de bloqueo del firewall si se confirma como IP externa o comprometida.
- **Bloqueo de dominio malicioso:** añadir malicious-site.com a las listas de bloqueo del proxy y DNS interno.
- **Segmentación de red:** revisar y reforzar las reglas de segmentación para impedir más movimiento lateral vía SMB.
- **Revocación de sesiones activas:** forzar el cierre de todas las sesiones de admin_temp en todos los sistemas.

4.4. Erradicación (Tier 3 / Forense)

Eliminación de persistencia:

- Eliminar la cuenta **admin_temp** de Active Directory y de todos los sistemas locales donde pueda haberse creado.
- Revisar y eliminar cualquier tarea programada, servicio o clave de registro creada por el malware para asegurar persistencia.
- Analizar GPO y políticas de AD para detectar cambios no autorizados realizados durante el ataque.

Limpieza de sistemas:

- Eliminar encryptor.exe y todos los artefactos maliciosos identificados por el EDR en cada endpoint comprometido.
- Realizar análisis forense completo de los sistemas afectados antes de proceder a la restauración.
- Verificar la integridad de los controladores de dominio y servidores críticos.
- Cambiar todas las contraseñas de cuentas administrativas y de servicio como medida preventiva.

4.5. Recuperación (IT / Negocio)

Restauración desde backups:

- Identificar los backups más recientes previos al incidente y verificar su integridad antes de iniciar la restauración.
- Restaurar los sistemas en orden de criticidad para el negocio, priorizando servidores de producción y datos críticos.
- Hay que asegurar que los backups utilizados para la restauración no estén comprometidos (verificar que no estén cifrados ni contaminados).

Validación de sistemas:

- Comprobar el funcionamiento correcto de todos los sistemas restaurados antes de reincorporarlos a la red de producción.
- Ejecutar análisis antimalware completo en cada sistema restaurado.
- Monitorizar de forma intensiva los sistemas restaurados durante al menos 72 horas tras la recuperación.
- Validar la autenticidad e integridad de los datos recuperados con los propietarios de la información.

4.6. Lecciones aprendidas (CISO / SOC)

Mejoras de seguridad:

- Implementar autenticación multifactor (MFA) para todos los accesos remotos y cuentas administrativas.
- Reforzar las políticas de contraseñas y habilitar alertas ante la creación de nuevas cuentas administrativas.
- Revisar y actualizar las reglas de correlación del SIEM para detectar patrones de fuerza bruta y creación de cuentas sospechosas en tiempo real.
- Segmentar la red para limitar el alcance del movimiento lateral vía SMB.

Controles preventivos:

- Implantar una política de whitelisting de aplicaciones (AppLocker o similar) para impedir la ejecución de binarios no autorizados como encryptor.exe.
- Habilitar el registro de PowerShell en todos los endpoints.
- Realizar simulacros de ransomware con el equipo de respuesta a incidentes.
- Revisar y probar periódicamente los backups para garantizar su disponibilidad en caso de incidente.

5. Diagrama de flujo

El siguiente diagrama de flujo describe el proceso de toma de decisiones y el árbol de escalado durante la respuesta al incidente de ransomware:

INICIO: Alerta SIEM / EDR detectada

↓

¿Es una alerta de cifrado masivo o creación de cuenta sospechosa?

SÍ → Tier 1 valida la alerta y escala inmediatamente a Tier 2

NO → Tier 1 investiga y descarta falso positivo

↓

Tier 2: Análisis y confirmación de compromiso

¿Se confirma ransomware activo con movimiento lateral?

SÍ → Contención inmediata (aislamiento, bloqueo cuentas) + escalar a Tier 3 y CISO

NO → Documentar y continuar monitorización

↓

Tier 3 + CISO: Erradicación y decisión de escalado externo

¿Afecta a datos personales o infraestructura crítica?

SÍ → Notificación a AEPD (si datos personales) y/o CCN-CERT (si infraestructura crítica)

NO → Erradicación interna + recuperación

↓

Recuperación → Lecciones aprendidas → Cierre del incidente

6. Escalado interno y externo

6.1. Criterios de escalado interno

Nivel	Responsable	Criterio de escalado
Tier 1 → Tier 2	SOC Tier 1 → Analista Tier 2	Alerta de cifrado masivo, creación de cuenta sospechosa o tráfico lateral detectado.
Tier 2 → Tier 3	Tier 2 → Equipo Forense / Tier 3	Compromiso confirmado, más de 3 equipos afectados, movimiento lateral activo o servidores críticos comprometidos.
Tier 3 → CISO	Tier 3 → CISO / Dirección	Impacto en continuidad de negocio, potencial exfiltración de datos, imposibilidad de contener el ataque internamente.

6.2. Justificación del escalado externo

Se considera necesario el escalado externo en los siguientes supuestos:

- **CCN-CERT:** Si la organización es parte de la Administración Pública o gestiona infraestructuras críticas, es obligatorio notificar al Centro Criptológico Nacional (CCN-CERT) de acuerdo con la normativa española de ciberseguridad (Esquema Nacional de Seguridad y Ley PIC).
- **AEPD (Agencia Española de Protección de Datos):** Si el incidente implica una brecha de datos personales, es obligatorio notificar a la AEPD en un plazo máximo de 72 horas desde que se tenga conocimiento de esta, conforme al Reglamento General de Protección de Datos (RGPD).
- **Fuerzas y Cuerpos de Seguridad del Estado:** Si se decide interponer denuncia por el delito informático sufrido, el incidente debe ser comunicado a la Brigada de Investigación Tecnológica (BIT) de la Policía Nacional o al

Grupo de Delitos Telemáticos (GDT) de la Guardia Civil, aportando toda la evidencia forense disponible.

- **Empresa de respuesta a incidentes externa (DFIR):** Si el equipo interno no dispone de capacidad suficiente para gestionar la erradicación completa del ransomware o se requiere análisis forense avanzado, se recomienda contratar una empresa especializada en análisis forense digital.

En este escenario concreto, dado que se ha detectado cifrado masivo de datos, creación de cuentas administrativas no autorizadas y movimiento lateral activo, el escalado externo estaría justificado si la organización gestiona datos personales de terceros, ya que existiría una alta probabilidad de brecha de datos notificable a la AEPD.